

Презентация по выполнению индивидуального проекта №5

Основы информационной безопасности

Осман АлиНиколай

2026-05-16

1 Информация

Раздел 1

Информация

Осман АлиНиколай

студент

Российского университета дружбы народов им. П. Лумумбы

1032239330@rudn.ru

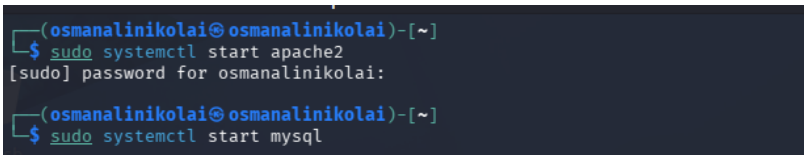


Цель

Научиться использовать Burp Suite.

Выполнение лабораторной работы

Запускаю локальный сервер, на котором открою веб-приложение DVWA для тестирования инструмента Burp Suite



```
(osmanalinikolai@osmanalinikolai)-[~]  
$ sudo systemctl start apache2  
[sudo] password for osmanalinikolai:  
  
(osmanalinikolai@osmanalinikolai)-[~]  
$ sudo systemctl start mysql
```

Рисунок 1: Запуск локального сервера

Выполнение лабораторной работы

Запускаю инструмент Burp Suite

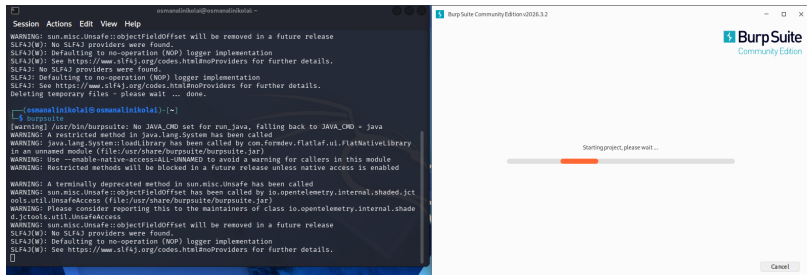


Рисунок 2: Запуск приложения

Выполнение лабораторной работы

Открываю сетевые настройки браузера, для подготовке к работе

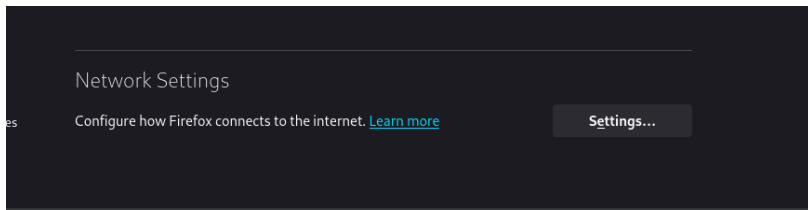
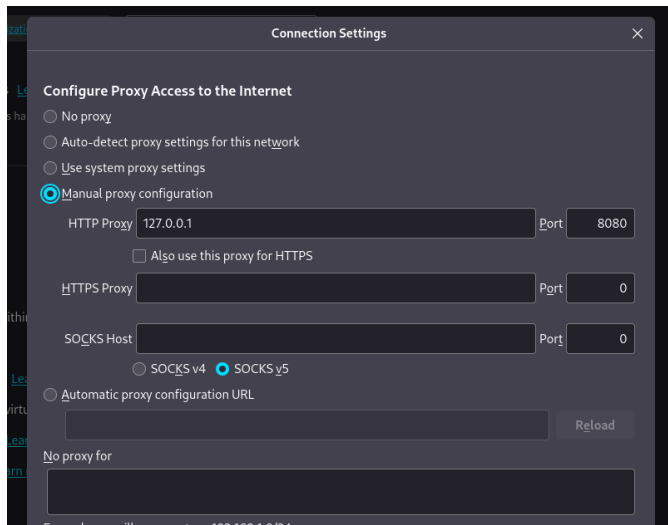


Рисунок 3: Сетевые настройки браузера

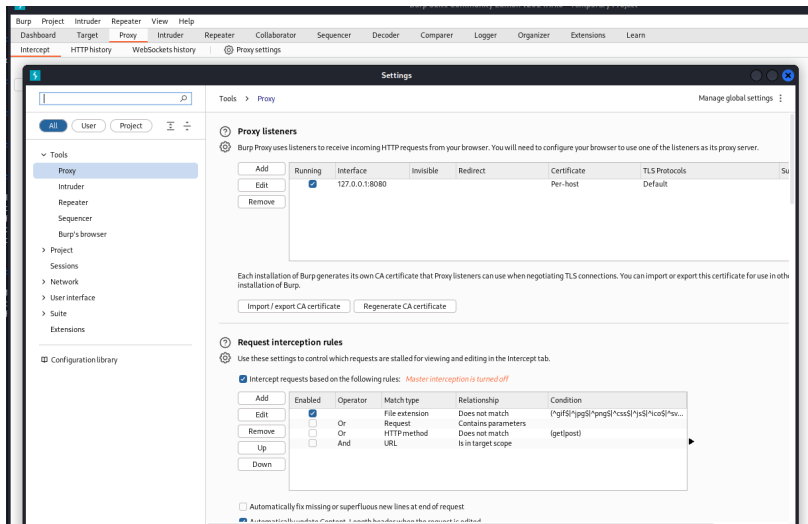
Выполнение лабораторной работы

Изменение настроек сервера для работы с прокси и захватом данных с помощью Burp Suite



Выполнение лабораторной работы

Изменяю настройки Прoxy инструмента Burp Suite для дальнейшей работы



Выполнение лабораторной работы

Во вкладке Proxy устанавливаю «Intercept is on»

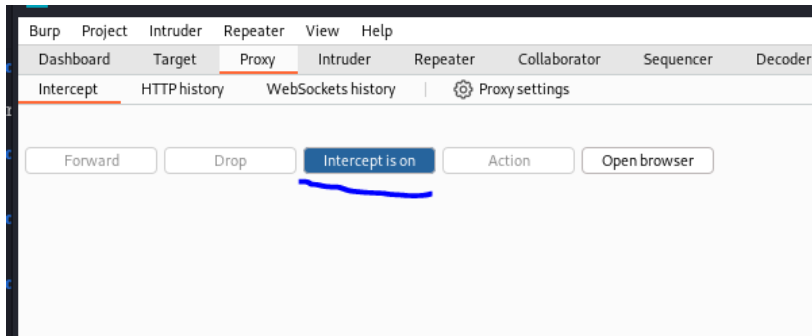


Рисунок 6: Настройки Proxy

Выполнение лабораторной работы

Чтобы Burp Suite исправно работал с локальным сервером, необходимо установить параметр `network.allow_hijacking_localhost` на `true`

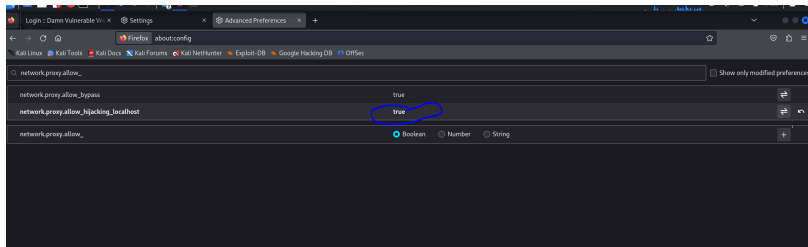


Рисунок 7: Настройки параметров

Выполнение лабораторной работы

Пытаюсь зайти в браузере на DVWA, тут же во вкладки Proxu появляется захваченный запрос. Нажимаем «Forward», чтобы загрузить страницу

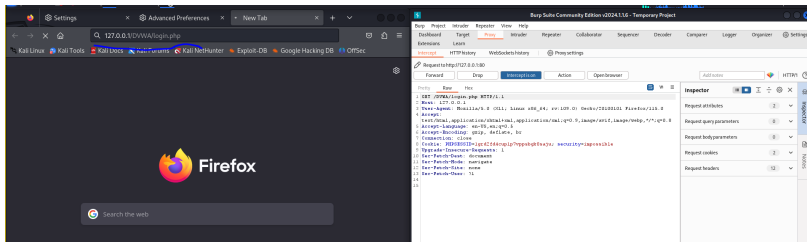


Рисунок 8: Получаемые запросы сервера

Выполнение лабораторной работы

Загрузилась страница авторизации, текст запроса поменялся

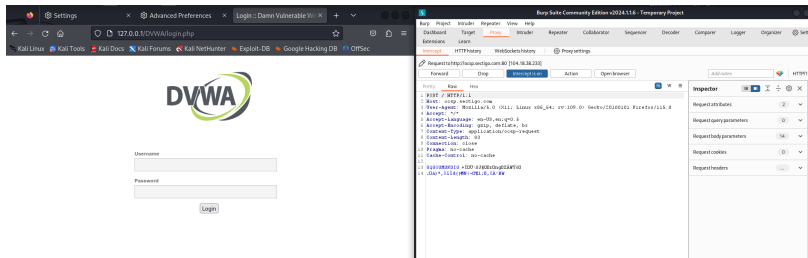


Рисунок 9: Страница авторизации

Выполнение лабораторной работы

История запросов хранится во вкладке Target

The screenshot displays the Burp Suite Community Edition v2024.11.6 interface. The 'Target' tab is active, showing a list of requests. The first request is a GET to /DVWA/login.php with a status code of 200. The 'Request' tab is selected in the bottom panel, showing the raw request details.

Host	Method	URL	Params	Status Code	Length	MIME type	Title
http://127.0.0.1	GET	/DVWA/login.php		200	1633	HTML	Login:: Damn Vulnera...
http://127.0.0.1	GET	/DVWA/dvwa/images...					

Request

```
1 GET /DVWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: close
8 Cookie: PHPSESSID=lgrdCfd4cuplp7vppsbgk8saju; security=impossible
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
```

Inspector

- Request attributes: 2
- Request cookies: 2
- Request headers: 12
- Response headers: 9

Выполнение лабораторной работы

Попробуем ввести неправильные, случайные данные в веб-приложении и нажмем Login. В запросе увидим строку, в которой отображаются введенные нами данные, то есть поле для ввода

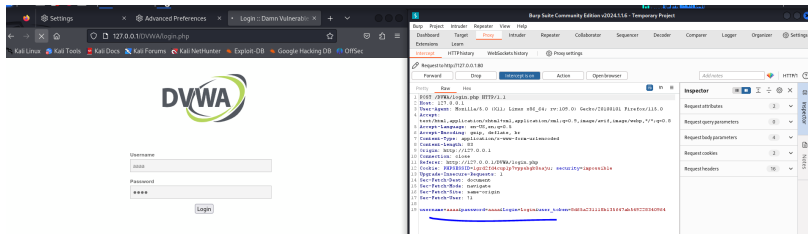
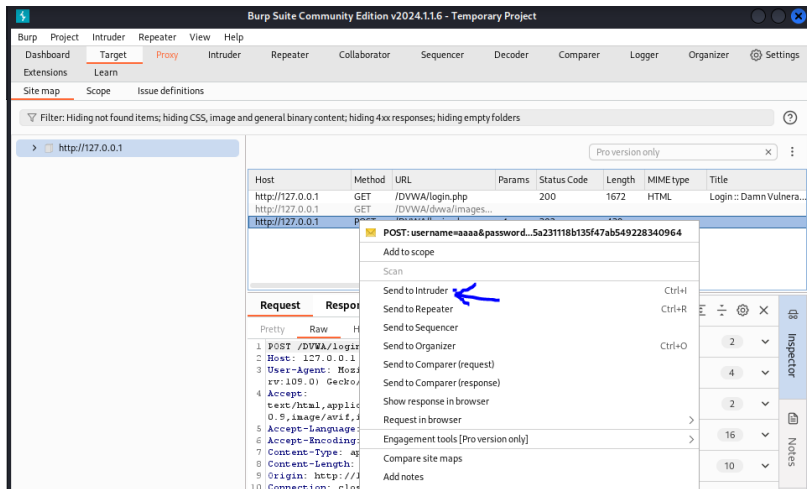


Рисунок 11: Ввод случайных данных

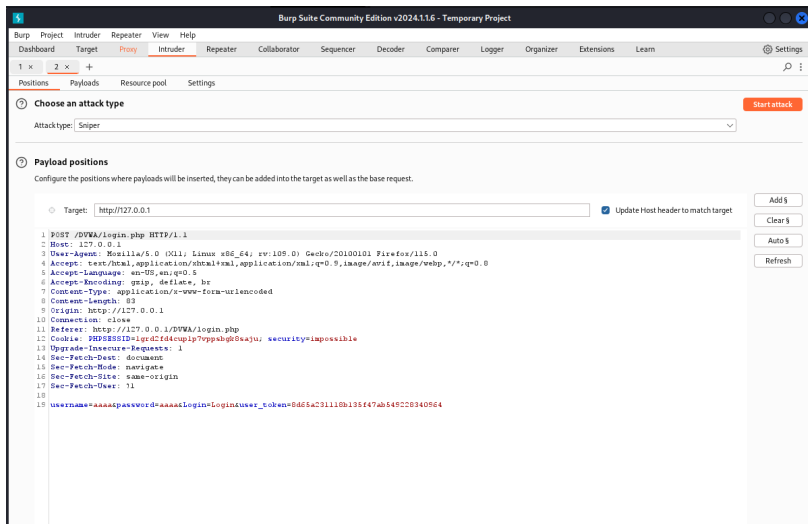
Выполнение лабораторной работы

Этот запрос так же можно найти во вкладке Target, там же жмем правой кнопкой мыши на хост нужного запроса, и далее нажимаем «Send to Intruder»



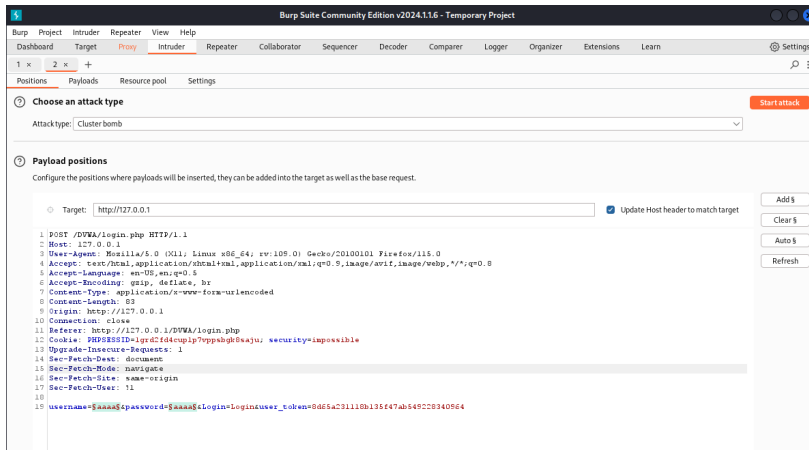
Выполнение лабораторной работы

Попадаем на вкладку Intruder, видим значения по умолчанию у типа атаки и наш запрос



Выполнение лабораторной работы

Изменяем значение типа атаки на Cluster bomb и проставляем специальные символы у тех данных в форме для ввода, которые будем пробивать, то есть у имени пользователя и пароля



Выполнение лабораторной работы

Так как мы отметили два параметра для подбора, то нам нужно два списка со значениями для подбора. Заполняем первый список в **Payload setting**

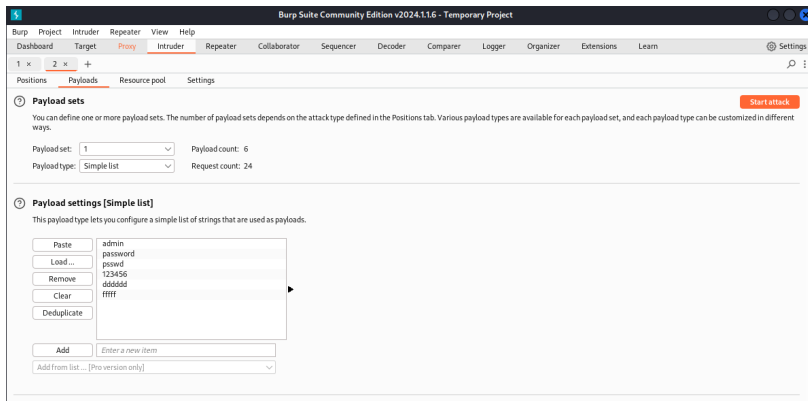


Рисунок 15: Первый Simple list

Выполнение лабораторной работы

Переключаемся на второй список и добавляем значения в него. В строке request count видим нужное количество запросов, чтобы проверить все возможные пары пользователь-пароль

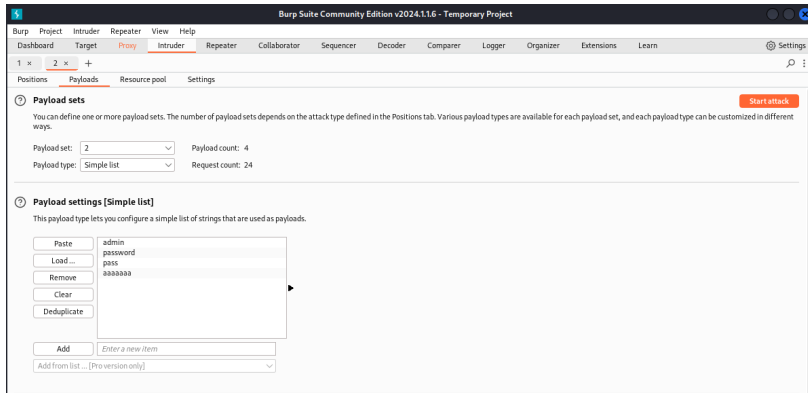
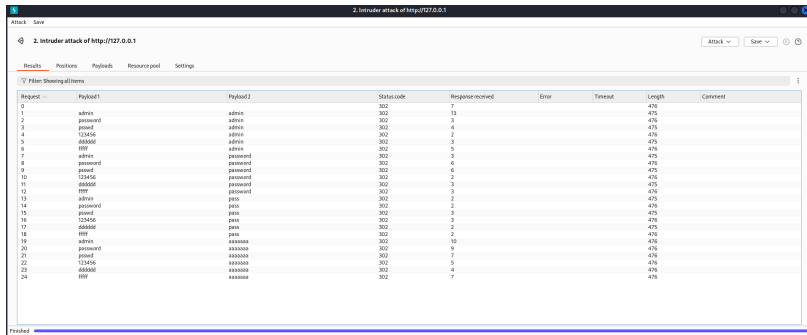


Рисунок 16: Второй Simple list

Выполнение лабораторной работы

Запускаю атаку и начинаю подбор



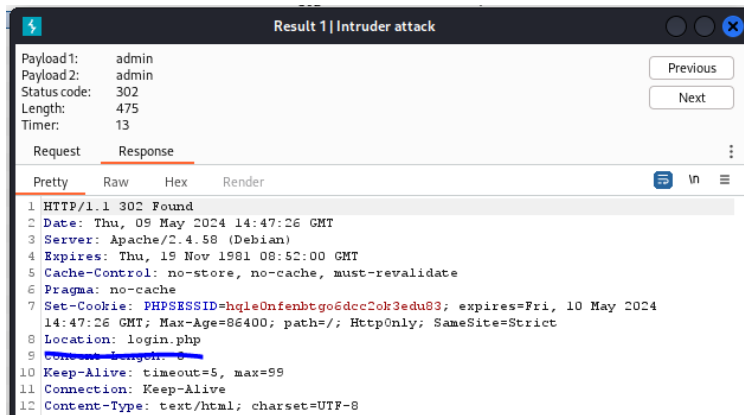
The screenshot shows the Burp Suite interface with the 'Intruder' tab selected. The title bar indicates '2. Intruder attack of http://127.0.0.1'. The main area displays a table of attack results. The table has columns for Request, Payload 1, Payload 2, Status code, Response received, Error, Timeout, Length, and Comment. The status codes are all 302, indicating successful redirects. The payloads include 'admin', 'password', '123456', 'aaaaaa', and '1111'. The response received is '302' for all requests. The length of the response is 476 bytes. The comment column is empty.

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
0			302	7			476	
1	admin	admin	302	13			476	
2	password	password	302	3			476	
3	123456	123456	302	4			476	
4	aaaaaa	aaaaaa	302	2			476	
5	1111	1111	302	3			476	
6	admin	password	302	5			476	
7	password	password	302	6			476	
8	123456	123456	302	6			476	
9	aaaaaa	aaaaaa	302	2			476	
10	1111	1111	302	3			476	
11	admin	password	302	2			476	
12	password	password	302	2			476	
13	123456	123456	302	2			476	
14	aaaaaa	aaaaaa	302	2			476	
15	1111	1111	302	2			476	
16	admin	password	302	2			476	
17	password	password	302	2			476	
18	123456	123456	302	2			476	
19	aaaaaa	aaaaaa	302	2			476	
20	1111	1111	302	2			476	
21	admin	password	302	9			476	
22	password	password	302	7			476	
23	123456	123456	302	5			476	
24	aaaaaa	aaaaaa	302	4			476	
25	1111	1111	302	7			476	

Рисунок 17: Запуск атаки

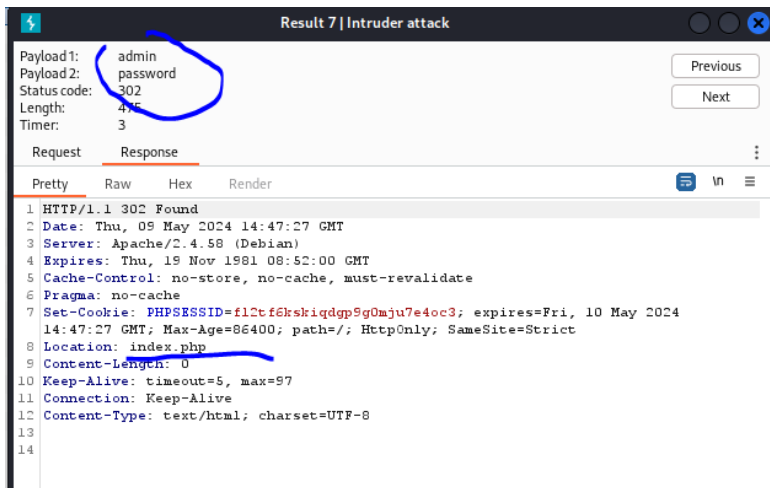
Выполнение лабораторной работы

При открытии результата каждого post-запроса можно увидеть полученный get-запрос, в нем видно, куда нас перенаправило после выполнения ввода пары пользователь-пароль. В представленном случае с подбором пары admin-admin нас перенаправило на login.php, это значит, что пара не подходит



Выполнение лабораторной работы

Проверим результат пары admin-password во вкладке Response, теперь нас перенаправляет на страницу index.php, значит пара должна быть верной



Выполнение лабораторной работы

Дополнительная проверка с использованием Repeater, нажимаем на нужный нам запрос правой кнопкой мыши и жмем «Send to Repeater»

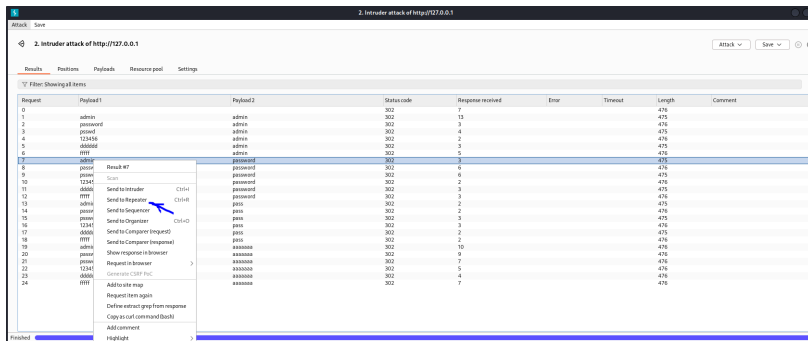
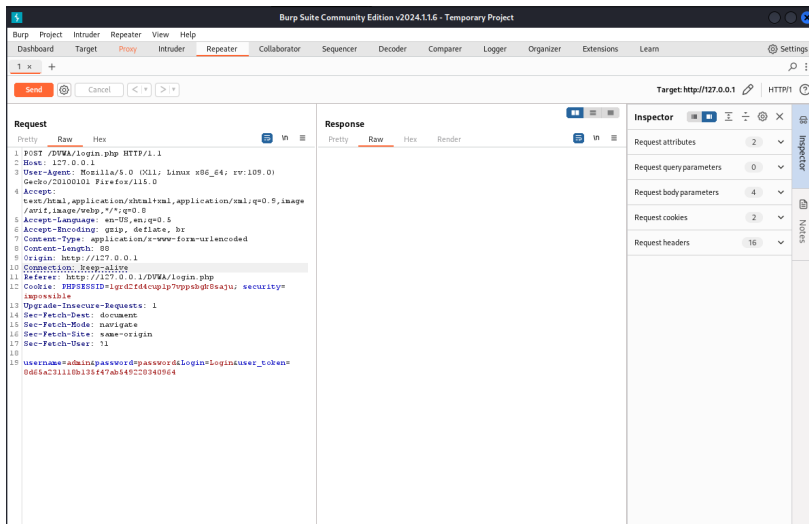


Рисунок 20: Дополнительная проверка результата

Выполнение лабораторной работы

Переходим во вкладку «Repeater»



Выполнение лабораторной работы

Нажимаем «send», получаем в Response в результат перенаправление на index.php

Burp Suite Community Edition v2024.1.16 - Temporary Project

Target: http://127.0.0.1 | HTTP/1

Request

```
1 POST /DVWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0)
  Gecko/20100101 Firefox/115.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image
  /svg,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 88
9 Origin: http://127.0.0.1
10 Connection: keep-alive
11 Referer: http://127.0.0.1/DVWA/login.php
12 Cookie: PHPSESSID=1grd2fd4cuplp7vppsbgk8saJu; security=
  impossible
13 Upgrade-Insecure-Requests: 1
14 Sec-Fetch-Dest: document
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-Site: same-origin
17 Sec-Fetch-User: 11
18
19 username=admin&password=password&login=Login&user_token=
  8d65a23110b135f47ab549228340964
```

Response

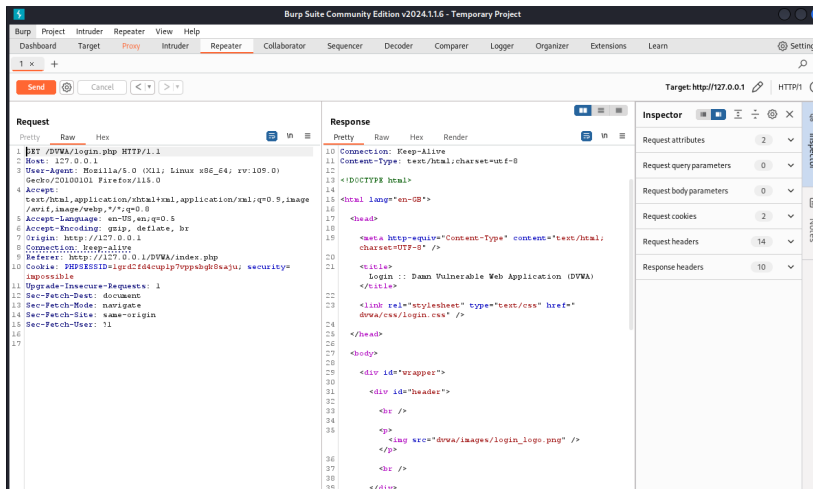
```
1 HTTP/1.1 302 Found
2 Date: Thu, 09 May 2024 14:51:42 GMT
3 Server: Apache/2.4.58 (Debian)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 Set-Cookie: PHPSESSID=dv7q7lumsiu7vb7wc7b886cr5;
  expires=Fri, 10 May 2024 14:51:42 GMT; Max-Age=86400;
  path=/; HttpOnly; SameSite=Strict
8 Location: index.php
9 Content-Length: 0
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
14
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 4
- Request cookies: 2
- Request headers: 16
- Response headers: 11

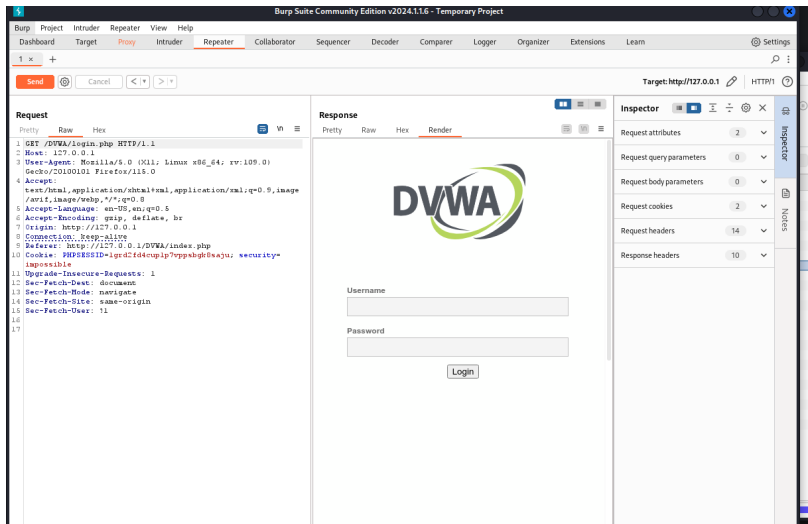
Выполнение лабораторной работы

После нажатия на Follow redirection, получим неcompiled html код в окне Response



Выполнение лабораторной работы

Далее в подокне Render получим то, как выглядит полученная страница



При выполнении лабораторной работы научился использовать инструмент Burp Suite.
...